

****October 5, 2023****

The Agency for the Protection of Personal Data has imposed an administrative monetary fine in the amount of €5,470,000.00 (41,213,715.00 kuna) on EOS Matrix d.o.o. as the data controller for the following established violations of the General Data Protection Regulation:

1. The data controller did not take appropriate technical measures to protect the processing of personal data of the data subjects contained in storage systems, which is contrary to Article 32, paragraph 1, point b) and paragraph 2 of the General Data Protection Regulation.
2. The data controller processed personal data of data subjects who are not in a debtor-creditor relationship in its database (application) without a legal basis under Article 6, paragraph 1 of the General Data Protection Regulation.
3. The data controller processed special categories of personal data (health data) of data subjects in its database (application) without a legal basis under Article 6, paragraph 1, and in relation to this, Article 9, paragraph 2 of the General Data Protection Regulation.
4. The data controller did not inform data subjects in a transparent and prescribed manner about the processing of their health data in privacy policies, which is contrary to Article 12, paragraph 1 of the General Data Protection Regulation and in relation to this, Article 13, paragraphs 1 and 2 of the General Data Protection Regulation.
5. For recording telephone conversations with data subjects from May 25, 2018, to January 16, 2019, the data controller did not have an established legal basis under Article 6, paragraph 1 of the General Data Protection Regulation, resulting in a violation of Article 5, paragraph 2 of the General Data Protection Regulation.
6. The data controller did not inform data subjects in a clear and understandable manner about the processing of personal data in the form of recording telephone conversations, thereby acting contrary to Article 12, paragraph 1 of the General Data Protection Regulation.

On March 22, 2023, the Agency for the Protection of Personal Data received an anonymous complaint stating that there had been unauthorized processing of a large number of personal data of individuals (debtors) by EOS Matrix d.o.o. The complaint included a USB stick containing 181,641 personal data of individuals in the structure of name and surname, date of birth, and OIB, who had outstanding debts to initial creditors that were purchased by EOS Matrix d.o.o. based on a contract of assignment. Furthermore, the complaint stated that the database also contained 294 individuals who were minors at the time the database was compiled.

Upon receiving the complaint, the Agency conducted a supervisory procedure over the data controller, EOS Matrix d.o.o. Regarding the aforementioned point 1, it was established that the data controller had not implemented sufficient technical measures of protection that could timely recognize activities

in the processing system (the main database in which it processes personal data of approximately 370,000 data subjects) that deviate from the norm (e.g., an increased number of data accesses in the database, data transfers outside the system, compromise of user access, etc.). A system that could alert to anomalies in the processing system and notify responsible persons via alarms and/or initiate automated measures to prevent further possible unauthorized activities was only implemented in 2021. Due to deficiencies in the security system, there was insecure processing of personal data of a large number of data subjects, and the company lost control over the movement of personal data of its data subjects and could not explain the causes or methods of data exfiltration, which further indicates the carelessness in handling a large number of personal data of its data subjects.

Namely, the aforementioned data controller did not appropriately implement technical measures to ensure an adequate level of security considering the risk, all in accordance with the provision of Article 32 of the General Data Protection Regulation.

In the supervisory procedure, it was established that EOS Matrix d.o.o. also processed personal data of individuals who are not debtors (most often telephone numbers, names, surnames, and residential addresses), nor legal representatives of heirs in debtor-creditor relationships, and for whom there was no legal basis under Article 6, paragraph 1 of the General Data Protection Regulation for their personal data to be actively entered into the database and further processed for the purpose of collecting claims of actual debtors.

Regarding the processing of health data, it was established that EOS Matrix d.o.o., after communication with data subjects, actively recorded comments related to the health status of debtors in its internal database for certain data subjects. The situation is particularly concerning where the health status of the relevant data subjects was monitored down to the details of specific diagnoses, including terminal illnesses, which almost maximally exposes someone's privacy to individuals authorized to access the application (database) used by employees of EOS Matrix d.o.o. The arguments of EOS Matrix d.o.o. that the data subjects themselves provided such information do not mean that the same can be actively entered into the database and thus enrich the database and further processed. For someone's health data to be actively recorded based on its disclosure by the data subject, the data subject would need to publicly disclose such data (e.g., through media, social networks, etc.), which certainly does not apply to a telephone conversation between two individuals, which can be considered a type of confidential conversation. Consequently, it cannot be considered that there is an

exception for the processing of health data under Article 9, paragraph 2, point e) of the General Data Protection Regulation in this specific case. Furthermore, invoking a legal basis regarding the execution of a contract, as well as legitimate interest (which the company referred to) cannot be a legal basis, as the processing of health data...

is not necessary to achieve the intended purpose. If the goal is better collection from the debtor and avoiding communication due to health conditions, then the same purpose could be achieved by noting a general comment on the need to avoid contact for a certain period due to the debtor's personal condition, without highlighting precise health data.

Furthermore, regarding the processing of health data, an examination of the first three privacy policies (which were in effect from May 25, 2018, to October 29, 2020) determined that EOS Matrix d.o.o. defined therein that it does not process and will not process health data. This manner of operation led to non-transparent processing of personal data, as respondents could not expect that their health data disclosed in a telephone conversation would be actively recorded in the database and further processed, resulting in violations mentioned in point 4. In this manner of processing, respondents were unaware that their health data was accessible to all authorized persons who have access to the relevant database of EOS Matrix d.o.o.

Similarly, in the period from May 25, 2018, to January 16, 2019, personal data of 49,850 respondents were processed by recording telephone conversations without establishing a legal basis under Article 6, paragraph 1 of the General Data Protection Regulation, and thus violating the provisions of Article 5, paragraph 2 of the General Data Protection Regulation. Namely, only on January 16, 2019, did EOS Matrix d.o.o. conduct a legitimate interest test and determine that it had a legal basis under Article 6, paragraph 1, point f) for recording telephone conversations. In this regard, it should be noted that legitimate interest is demonstrated in such a way that the data controller must prove prior to the moment of processing personal data that, regarding the specific processing of personal data, its rights to proceed with such processing (specifically recording telephone conversations) outweigh the interests and rights and freedoms of the respondents or debtors.

Furthermore, regarding the recording of telephone conversations, it was established that EOS Matrix d.o.o. has been using the functionality of recording telephone conversations with debtors since 2014 (relevant from May 25, 2018) and indicates that the conversation "may" be recorded. All data controllers, in any processing of personal data, are obliged to proactively communicate to respondents clearly, unambiguously, and in understandable language all their rights under the General Data Protection Regulation. Namely, by using the construction "may be recorded," debtors were uncertain whether the conversation was being recorded or could only be recorded in certain situations, and thus they did not know whether their personal data was being processed in this way or not. EOS Matrix d.o.o. should have used a clear linguistic formulation "this conversation is being recorded for the purpose of..." thereby respecting the provision of Article 12, paragraph 1 of the General Data Protection Regulation, whereas in this way, a violation occurred. During the supervisory procedure, the Agency also examined the claims from the received complaint regarding the processing of personal data of minors and established that such data is processed only in the case of inheritance, donations, and in those cases, proactive communication for the purpose of debt settlement is conducted exclusively through the legal representative of the minor. Namely, EOS Matrix d.o.o. does not pursue collection against minors, and in the event that they receive data relating to minors, they return it to the sender or, in the case of inability to recover the debt, write it off.

In the specific case, it was not established how exactly the exfiltration of 181,641 personal data occurred, considering that this case involves a potential commission of a criminal offense of unauthorized use of personal data and criminal offenses against computer systems, programs, and data, which falls under the jurisdiction of the Ministry of the Interior. It should be noted that the Agency is actively cooperating with the Zagreb Police Department and the Municipal State Attorney's Office in Zagreb, which are conducting investigative actions.

Namely, although EOS Matrix d.o.o. denies that personal data has been extracted from their storage system and states that these personal data are also held by state administration bodies, it is important to emphasize that the information that a certain person is in a debtor-creditor relationship with EOS Matrix d.o.o., along with other personal data, is not recorded in any storage system of other institutions, except in the system of EOS Matrix d.o.o., while individual primary creditors could only dispose of data limited to their clients/debtors, whose debts were sold to EOS Matrix d.o.o. Consequently, it has been unequivocally established that the personal data provided to the Agency via USB stick was extracted from the database of EOS Matrix d.o.o.